

HIPAA Security Rule - Safeguard Compliance Assessment (SCA)

Administrative Safeguards – ADM-01 to ADM-08

```
=====
>>> DEMONSTRATION VERSION (Proof-of-Concept) <<<
>>> First 8 Controls Only -- For Evaluation Purposes <<<
=====
```

```
=====
HIPAA Security Rule - Safeguard Compliance Assessment (SCA)
Expert System (ES) (v1.0)
Administrative Safeguards | Controls ADM-01 to ADM-08
45 CFR Part 164 Security Rule | HHS RIN 0945-AA22 NPRM
-----
```

```
Copyright 2026. Thomas P. Dover. All Rights Reserved.
Contact: tdover@pas-lp.com | tpd_phd@yahoo.com
=====
```

ABOUT ADMINISTRATIVE SAFEGUARDS

```
=====
```

Each 'Covered Entity' (Healthcare Delivery Organization) and 'Business Associate' (Contractor, Vendor, 3rd Party) must, in accordance with §§ 164.306 (General Rules) and 164.316 (Policies, Procedures, and Documentation Requirements), implement safeguards to protect the confidentiality, integrity, and availability of all electronic protected health information that it creates, receives, maintains, or transmits.

```
=====
```

```
+++ ASSESSMENT COMPLETE +++
Assessment Date: 08-01-2026
Completed by : Adam B. User
Title : Security Analyst
Organization : MyHealthCare company
```

RESULTS

```
=====
```

```
=====
HIPAA SCA ASSESSMENT REPORT
Administrative Safeguards | ADM-01 to ADM-08
=====
```

STATISTICS

```
-----
```

```
TOTAL SCORE : 3.5 / 8.0
PERCENTAGE : 43.75%
```

```
Compliant : 2
Partial : 1
Non-compliant : 4
Does Not Apply : 1 (scored as compliant)
```

ANSWER KEY

Control	Ans	Score	Finding	Rule Source
ADM-01	Y	1.0	Compliant	NPRM
ADM-02	N	0.0	Non-compliant	NPRM
ADM-03	P	0.5	Partial Compliance	NPRM
ADM-04	A	1.0	Compliant	NPRM
ADM-05	U	0.0	Non-compliant	SR-RE
ADM-06	D	1.0	Does Not Apply	SR-RE
ADM-07	U	0.0	Non-compliant	SR-RE
ADM-08	U	0.0	Non-compliant	SR-RE

=====

COMPLIANT

=====

[ADM-01]**Standard:** TECHNOLOGY ASSET INVENTORY**Specification:** 164.308 (ii) (A) [Inventory]**Rule Source:** A new standard proposed by the NPRM**Question:** Has your organization developed a written inventory of your technology assets that contains the identification, version, person accountable, and location of each technology asset?**Answer:** Y | **Finding:** Compliant**[ADM-04]****Standard:** TECHNOLOGY ASSET INVENTORY**Specification:** 164.308 (a) (1) (ii) (C) (2) [Maintenance]**Rule Source:** A new standard proposed by the NPRM**Question:** Does your organization perform maintenance to its 'Technology Asset Inventory' when there is a change in your environment or operations that may affect electronic protected health information, including but not limited to the adoption of new technology assets; the upgrading, updating, or patching of technology assets; newly recognized threats to the confidentiality, integrity, or availability of electronic protected health information; a sale, transfer, merger, or consolidation of all or part of your organization; a security incident that affects the confidentiality, integrity, and availability of electronic protected health information; and/or relevant changes in Federal, State, Tribal, or territorial law?**Answer:** ALT | **Finding:** Compliant

=====

NON-COMPLIANT AND PARTIAL COMPLIANCE | RECOMMENDATIONS AND GUIDANCE

=====

[ADM-02]**Standard:** TECHNOLOGY ASSET INVENTORY**Specification:** 164.308 (ii) (B) [Network Map]**Rule Source:** A new standard proposed by the NPRM**Question:** Has your organization developed a network map that illustrates the movement of electronic protected health information throughout your electronic information systems, including but not limited to, how electronic protected health enters and exits such information systems, and is accessed from outside of

such information systems?

Answer: N | **Finding:** Non-compliant

Guidance: Create a written network map showing how ePHI moves through all your electronic information systems. Include all systems, connections, and data flows. Assign an owner and keep it current.

Technical: Develop a network map per CM-12 that illustrates all ePHI movement across relevant electronic information systems. Align with system component inventory per CM-8 and system security plan per PL-8.

Reference: NIST SP 800-53r5 | Configuration Management (CM) | Sections: CM-8, CM-12, PL-8 | Pages: 107, 112, 193

[ADM-03]

Standard: TECHNOLOGY ASSET INVENTORY

Specification: 164.308 (a)(1)(ii)(C)(1) [Maintenance]

Rule Source: A new standard proposed by the NPRM

Question: On an ongoing basis, but at least once every 12 months, does your organization review and update your written 'Technology Asset Inventory'?

Answer: P | **Finding:** Partial Compliance

Guidance: Establish a documented annual review cycle for your technology asset inventory. Assign responsibility for completing and recording the review each year.

Technical: Formalize the annual review process for the asset inventory per CM-8(2). Document review results and update the inventory to reflect current system state per CM-8(1).

Reference: NIST SP 800-53r5 | Configuration Management (CM) | Sections: CM-8(1), CM-8(2) | Pages: 108

[ADM-05]

Standard: RISK ANALYSIS

Specification: 164.308 (ii)(A)(1) [Assessment]

Rule Source: A REQUIRED standard in the current Security Rule but enhanced by the NPRM

Question: Does your organization perform or conduct a review of the technology asset inventory and the network map to identify where electronic protected health information may be created, received, maintained, or transmitted within your electronic information systems?

Answer: U | **Finding:** Non-compliant

Guidance: Review your technology asset inventory and network map to identify every location where ePHI is created, received, maintained, or transmitted. Document all findings as the foundation of your risk analysis.

Technical: Conduct a scope assessment per RA-3(1) using the system component inventory (CM-8) and network map to identify all ePHI locations as the basis for risk analysis.

Reference: NIST SP 800-53r5 | Risk Assessment (RA) | Sections: RA-3, RA-3(1) | Pages: 256, 257

[ADM-07]

Standard: RISK ANALYSIS

Specification: 164.308 (ii)(A)(3) [Assessment]

Rule Source: A REQUIRED standard in the current Security Rule but enhanced by the NPRM

Question: Does your organization identify potential vulnerabilities and

predisposing conditions to your relevant electronic information systems?

Answer: U | **Finding:** Non-compliant

Guidance: Identify and document all potential vulnerabilities and predisposing conditions in your electronic information systems that could be exploited by identified threats.

Technical: Conduct and document vulnerability identification per RA-3 and RA-5 covering system weaknesses and predisposing conditions across all relevant electronic information systems.

Reference: NIST SP 800-53r5 | Risk Assessment (RA) | Sections: RA-3, RA-5 | Pages: 256, 259

[ADM-08]

Standard: RISK ANALYSIS

Specification: 164.308 (ii) (A) (4) [Assessment]

Rule Source: A REQUIRED standard in the current Security Rule but enhanced by the NPRM

Question: Does your organization perform an assessment (including documentation) of the security measures you use to ensure the confidentiality, integrity, and availability of the electronic protected health information created, received, maintained, or transmitted by your organization?

Answer: U | **Finding:** Non-compliant

Guidance: Assess and document all security measures currently in place to protect the confidentiality, integrity, and availability of your ePHI. Include both technical and administrative controls.

Technical: Perform and document a control assessment per CA-2 to evaluate all security measures protecting ePHI CIA. Integrate findings into risk assessment per RA-3.

Reference: NIST SP 800-53r5 | Risk Assessment (RA), Assessment, Authorization, and Monitoring (CA) | Sections: RA-3, CA-2 | Pages: 256, 96

=====
NOT APPLICABLE
=====

Requirements marked Does Not Apply (DNA) are scored as compliant but listed here for auditor review. Each DNA determination should be documented with a written rationale.

[ADM-06]

Standard: RISK ANALYSIS

Specification: 164.308 (ii) (A) (2) [Assessment]

Rule Source: A REQUIRED standard in the current Security Rule but enhanced by the NPRM

Question: Does your organization identify all reasonably anticipated threats to the confidentiality, integrity, and availability of electronic protected health information that your organization creates, receives, maintains, or transmits?

Answer: DNA | **Finding:** Does Not Apply

=====
DISCLAIMER
=====

This assessment is provided for informational purposes only. It does not constitute legal advice. The questions and scoring are based on the HHS RIN 0945-AA22 Notice of Proposed Rulemaking (NPRM) for the HIPAA Security Rule. Question text has been modified for readability. Please refer to HHS RIN 0945-AA22 NPRM for the official regulatory

text and requirements. Results should be reviewed by a
qualified compliance professional.

=====